
School name Audit Report: Edmund De Moundeford Audit Date: 3 March 2020**Report: Year 2 visit 3****DPE: Linda Mortimer****School member: Office Manager: Kirsty Blight**

1. Visit details

Details highlighted at the time of the last visit were discussed and GDPR documents and policies were reviewed. The visit also included a review of the compliance checklists completed to date, a draft list of management processed to be actioned in the record of processing tool, and a review of how Compliance Manager can be used by the school to share policies and guidance with staff. An audit walk was not carried out at the time of this visit.

2. Findings at time of Audit 27.11.19

All actions highlighted at time of the audit carried out on 27.11.19 have been completed with the exception of:

The Freedom of Information Policy and Freedom of Information Publication Scheme: The FOI Policy is now published on the school website. The school needs to create its Freedom of Information Publication Scheme.

3. Audit and Findings on 3 March 2020

Freedom of Information Publication Scheme: The school needs to publish an FOI Publication Scheme.

Action: Further information about the FOI publication Scheme can be found under the News tab on Knowledge Bank. DPE will send an example of a completed Publication Scheme, based on the ICO template. Once ratified, this document should be published on the school's website.

Privacy Notice: The school currently has a Student Privacy Notice in place.

Action: As the current Privacy Notice does not cover staff, it was suggested that the school adopt the DPE model Privacy Notice which covers students and staff.

The Privacy Notice needs to include a detailed list of third parties with whom the school shares PII data. DPE will provide an example list.

Management and Retention of Student Images Electronic Archiving of Documents: There is now a secure area on the server for storing student images. Staff are aware that they need to regularly delete student images from iPads. Images to be archived for historical purposes are retained and uploaded to the secure area.

Electronic Archiving of Documents: The school is currently archiving old HR files by scanning and uploading to a secure area on the server. This practice will then be implemented across other areas, and by minimizing hard paper copies the school reduces the risk of sharing PII data. The school works in accordance with relevant retention guidelines – refer to the IRMS Toolkit.

Website Cleansing: The school works with its website provider to identify any out of date information / student images, and these are cleansed on at least an annual basis.

GDPR Training

GDPR 101 Online Training: The majority of staff have completed this training.

Action: Any outstanding training will be identified and where appropriate, the Office Manager will provide support in order that staff can complete this essential training.

Other Training: The school has used DPE's Password Security and Data Breach online training, available on Knowledge Bank.

Action: Remaining staff to complete online training for Password Security and Data Breach.

SAR Training: As well as the SAR Procedure there is now SAR online training available on the Knowledge Bank.

Action: The Headteacher, Leadership Team and senior Admin staff will complete the online SAR training.

Clear Desk and Screen Policy: The DPE draft policy was shared with all staff via Compliance Manager at the time of the visit.

Action: Monitor staff responses 'Acknowledge and Understood' and 'Used in Practice'.

Refreshed GDPR Training: DPE recommend that all staff undergo a GDPR refresher training every 2 years. There will be a 20-minute refresher course available shortly on Knowledge Bank.

Review of Best Practice Checklists: These were reviewed at the time of the visit and the Office Manager completed many of the checklists.

Action: Review remaining checklists with the Headteacher by the end of Summer Term 2020.

Working away from School Policy: The DPE model policy has been reviewed by the Headteacher.

Action: This policy will be presented to the Governing Body for ratification. This policy could be shared with staff via Compliance Manager.

Breach Log: At present the school uses its own Breach Log and all staff are aware of the Breach Procedure.

Action: In future the school will use the DPE Breach Log available on Knowledge Bank. The 'Data Breach Received' tab was explained. For 'less significant breaches' the school will continue to internally monitor and log, as before.

Consent Form: The school will compare the school's current Consent Form with the recommended DPE model.

Action: The Consent Form will be updated to include the Year 6 Leavers autograph book, which includes a photo of the student and also sharing images with media (as appropriate).

Action: The school will re-issue the amended Consent Form in the summer term, to the whole school and students due to start school in September.

Management of Cleaning: The school operates with its own in-house cleaners. Areas where confidential / sensitive information is stored is cleaned by the Caretaker only ie Headteachers Office and Main Office. This limits the risk of access to confidential data. The school has an electronic, key pass-coded Salto lock system in place across the site. This provide the school very robust access at all times.

Management of Hard Copy Information Sharing: The Office Manager ensures that any reports / letters including PII data are given directly to the member of staff and not passed to them via pigeonhole.

Action: Office Manager to routinely checks pigeonholes to ensure that no confidential information is stored in this area.

Management of School Catering: The school is changing its catering provider from Edwards and Blake to Dolce from Summer Term 2020. The new provider will be offering Cashless Catering and any information relating to student allergies will be retained electronically on the new system.

Action: DPE recommends that given the significant amount of PII data that will be required by the new provider, a Data Protection Impact Assessment should be completed. This will help highlight any risks and note mitigating actions that

could be initiated to safeguard PII data. The completed DPIA should be shared with the Governing Body for their consideration and to ensure transparency is achieved.

DPE suggests that the school contacts other Norfolk schools who have use this company. This would allow the school to be prepared for any problems that may arise regarding the roll out of the programme, be aware of the level of PII data that the company will require and how this will be safeguarded by the company.

School Server – Is situated in a locked cabinet and access to this room is restricted. Back up of the school server is managed by the Office Manager and these are stored offsite.

Compliance actions that should now be completed

Initial documents:

- **Privacy Notice** – school will review Star Accounts to identify any additional third parties
- **GDPR Policy** – this policy is up for renewal and being presented to the Governing Body on 10.12.19. The policy will then be uploaded to the school website
- **Data Breach Procedure**
- **SAR procedure**
- **Photo and Video consent, guidelines and records**

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

3.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: copy provided by DPE
- DfE toolkit
https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf (Annex 5,1)

3.2. Staff training

GDPR training should be completed and documented. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

3.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

The Best Practice checklists form a Data Dashboard for the school and clearly demonstrates the level of progress made in key areas.

3.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

4. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

5. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

5.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

6. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>